CNO V: SEGURIDAD INFORMÁTICA

UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

IMPLEMENTACIÓN DE INFRAESTRUCTURA SMTP PARA SIMULACIÓN DE ATAQUES DE INGENIERÍA SOCIAL CON SET

ACTIVIDAD 15

INTEGRANTES

Edwin Admael Castillo Gómez	181700
Carlos René Castillo Olvera	182033
Diego Osvaldo Hernández Fernández	182217
Tristan Rivera Magdalena Yesenia	174702

Docente: Servando López Contreras

Fecha: 27/04/2026

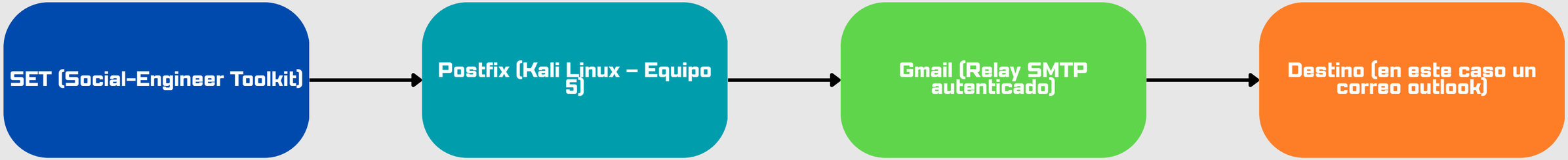
OBJETIVO

El objetivo de esta práctica fue simular el funcionamiento técnico de un atacante en el envío de correos mediante herramientas de ingeniería social, específicamente utilizando el Social-Engineer Toolkit (SET) sobre Kali Linux.

El Social-Engineer Toolkit (SET) fue creado y escrito por Dave Kennedy, fundador de TrustedSec. Se trata de una herramienta de código abierto, basada en Python, destinada a realizar pruebas de penetración mediante técnicas de ingeniería social.
Se ha presentado en conferencias de gran envergadura como Black Hat, DerbyCon, Defcon y ShmooCon. Con más de dos millones de descargas, es el estándar para las pruebas de penetración de ingeniería social y cuenta con un amplio respaldo dentro de la comunidad de seguridad.

ARQUITECTURA DE LA SOLUCIÓN

Se diseñó una cadena de envío de tres etapas para superar las restricciones de entrega directa impuestas por los proveedores de correo modernos:



El uso de un relay SMTP externo (Gmail) fue necesario dado que el envío directo desde una IP residencial es bloqueado por los filtros anti-spam de los proveedores destinatarios.

CONFIGURACIÓN E IMPLEMENTACIÓN

PREPARACIÓN DE CUENTA DE ENVÍO (GMAIL)

Se utilizó una cuenta de Gmail dedicada exclusivamente a esta práctica (equipo5testingset@gmail.com) para evitar comprometer cuentas personales.

ACTIVACIÓN DE AUTENTICACIÓN EN DOS PASOS

Google requiere 2FA activo para poder generar contraseñas de aplicación. El proceso seguido fue:

- Acceder a myaccount.google.com/security
- Activar Verificación en 2 pasos mediante número telefónico.
- Agregar Google Authenticator como método adicional (requisito para desbloquear App Passwords).

GENERACIÓN DE APP PASSWORD

Desde myaccount.google.com/apppasswords se generó una contraseña de 16 dígitos etiquetada como Postfix Kali Equipo 5. Esta contraseña permite autenticar el relay sin exponer la contraseña principal de la cuenta y puede revocarse al finalizar la práctica.

CONFIGURACIÓN E IMPLEMENTACIÓN

HOSTNAME DEL SERVIDOR

Se configuró el hostname del sistema operativo y del archivo /etc/hosts para que Postfix lo reconozca correctamente:

1

```
┌──(kali㉿kali)-[~]
└─$ sudo hostnamectl set-hostname "Equipo5"
```

2

```
┌──(kali㉿kali)-[~]
└─$ sudo nano /etc/hosts
```

3

```
#127.0.0.1       localhost
#127.0.1.1       kali
127.0.0.1   localhost
127.0.1.1   mail.equipo5.local mail
::1             localhost ip6-localhost ip6-loopback
```

CONFIGURACIÓN E IMPLEMENTACIÓN

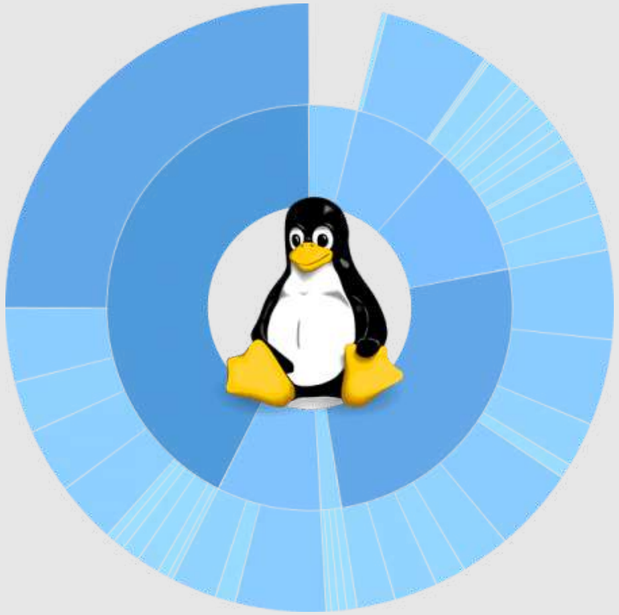
INSTALACIÓN DE POSTFIX

Durante la instalación se seleccionó el modo Internet Site.

```
┌──(kali㉿kali)-[~]
└─$ sudo apt install postfix -y
[sudo] password for kali:
```

Si parte de la instalación marca error, intentar solucionar con:

```
┌──(kali㉿kali)-[~]
└─$ sudo apt install --fix-missing postfix -y
```



CONFIGURACIÓN E IMPLEMENTACIÓN

CONFIGURACIÓN DE POSTFIX (/ETC/POSTFIX/MAIN.CF)

La configuración final del servidor queda de la siguiente manera, podemos comentar todo lo que contiene el main.cf y al final dejarlo como:

```
# See /usr/share/postfix/main.cf.dist for a commented, more complete version

# See http://www.postfix.org/COMPATIBILITY_README.html
compatibility_level = 3.11

# Which domain that locally-originated mail appears to come from.
# Debian policy suggests to read this value from /etc/mailname.
#XX needs a review in postinst&config
#myorigin = /etc/mailname
myorigin = $mydomain
#myorigin = $myhostname

myhostname = mail.equipo5.local
mydomain = equipo5.local
inet_interfaces = all
inet_protocols = ipv4

# Text that follows the 220 code in the SMTP server's greeting banner.
# You MUST specify $myhostname at the start due to an RFC requirement.
smtpd_banner = $myhostname ESMTP $mail_name (Debian)

# IP protocols to use: ipv4, ipv6, or all
# (set this explicitly so 'post-install upgrade-configuration' wont complain)
#inet_protocols = all

# List of "trusted" SMTP clients (maptype:mapname allowed) that have more
# privileges than "strangers".  If mynetworks is not specified (the default),
# mynetworks_style is used to compute its value.
#mynetworks_style = class
#mynetworks_style = subnet
mynetworks_style = host
#
mynetworks = 127.0.0.0/8 [::ffff:127.0.0.0]/104 [::1]/128

# Uncomment the next line to generate "delayed mail" warnings
#delay_warning_time = 4h

# List of domains (maptype:mapname allowed) that this machine considers
# itself the final destination for.
mydestination = $myhostname, localhost.$mydomain, localhost, $mydomain

# Maximum size of a user mailbox
mailbox_size_limit = 0
```

```
alias_database = hash:/etc/aliases

# Notify (or not) local biff service when new mail arrives.
# Rarely used these days.
biff = no

# Separator between user name and address extension (user+foo@domain)
#recipient_delimiter = +
recipient_delimiter = +

# A host to send "other" mail to
#relayhost = $mydomain
#relayhost = [gateway.example.com]
#relayhost = [ip.add.re.ss]:port
#relayhost = uucphost
#relayhost =
relayhost = [smtp.gmail.com]:587

# Where to look for Cyrus SASL configuration files.  Upstream default is unset
# (use compiled-in SASL library default), Debian Policy says it should be
# /etc/postfix/sasl.
cyrus_sasl_config_path = /etc/postfix/sasl

# SMTP server RSA key and certificate in PEM format
smtpd_tls_key_file = /etc/ssl/private/ssl-cert-snakeoil.key
smtpd_tls_cert_file = /etc/ssl/certs/ssl-cert-snakeoil.pem
# SMTP Server security level: none|may|encrypt
#smtpd_tls_security_level = may

# List of CAs for SMTP Client to trust
# Prefer this over _CApath when smtp is running chrooted
smtp_tls_CAfile = /etc/ssl/certs/ca-certificates.crt
# SMTP Client TLS security level: none|may|encrypt|...
smtp_tls_security_level = may
# SMTP Client TLS session cache
smtp_tls_session_cache_database = btree:${data_directory}/smtp_scache
smtpd_relay_restrictions = permit_mynetworks permit_sasl_authenticated defer_unauth_destination
#myhostname = kali
inet_interfaces = all
home_mailbox = Maildir/

smtp_sasl_auth_enable = yes
#smtp_sasl_password_maps = hash:/etc/postfix/sasl_passwd
smtp_sasl_password_maps = cdb:/etc/postfix/sasl_passwd
smtp_sasl_security_options = noanonymous
smtp_use_tls = yes
smtp_tls_security_level = encrypt
```

CONFIGURACIÓN E IMPLEMENTACIÓN

CONFIGURACIÓN DE POSTFIX (/ETC/POSTFIX/MAIN.CF)

Lo importante es tener lo siguiente dentro de nuestro main.cf:

```
myhostname = Equipo5
mydomain = equipo5.local
myorigin = $mydomain
inet_interfaces = all
inet_protocols = ipv4
mydestination = $myhostname, localhost.$mydomain, localhost, $mydomain
home_mailbox = Maildir/

# Relay SMTP
relayhost = [smtp.gmail.com]:587
smtp_sasl_auth_enable = yes
smtp_sasl_password_maps = cdb:/etc/postfix/sasl_passwd
smtp_sasl_security_options = noanonymous
smtp_use_tls = yes
smtp_tls_security_level = encrypt
```

CONFIGURACIÓN E IMPLEMENTACIÓN

CONFIGURACIÓN DE CREDENCIALES SASL

Configuramos nuestras credenciales que nos dió gmail en las contraseñas de aplicaciones :

1

```
┌──(kali㉿kali)-[~]
└─$ sudo nano /etc/postfix/sasl_passwd
```

2

```
  GNU nano 8.6                                  /etc/postfix/sasl_passwd
[smtp.gmail.com]:587 equipo5testingset@gmail.com:[redacted]
```

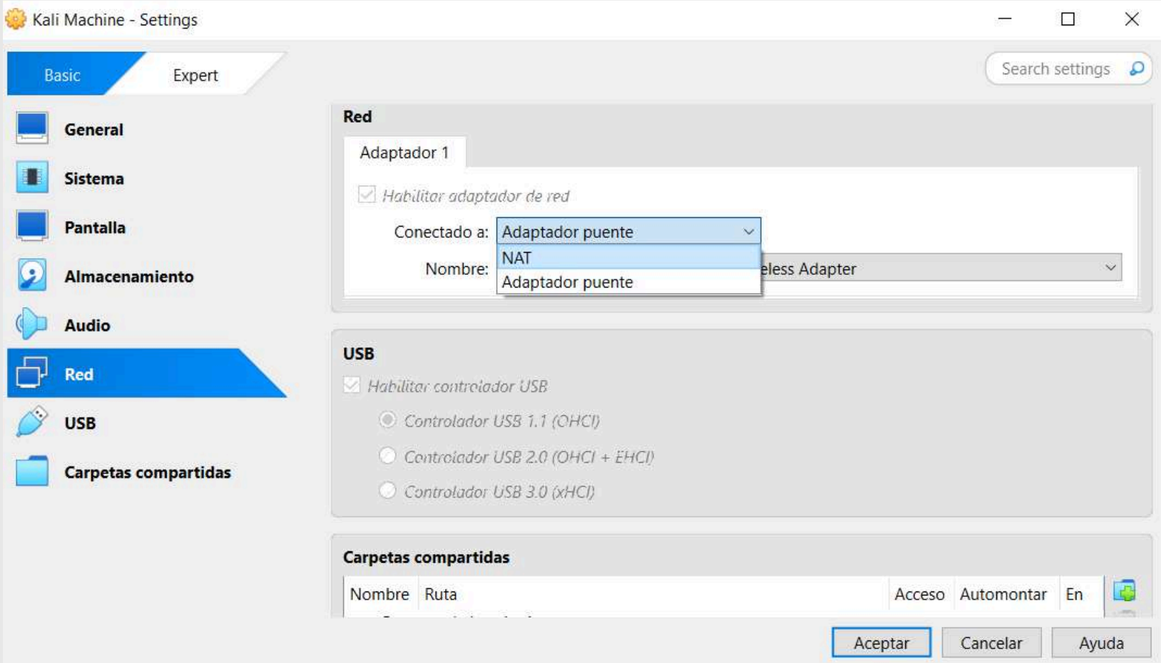
Debemos tener una contraseña de 16 digitos separada por espacios cada 4.

[smtp.gmail.com]:587 equipo5testingset@gmail.com:xxxx xxxx xxxx xxxx

CONFIGURACIÓN E IMPLEMENTACIÓN

CONFIGURACIÓN DE RED DE LA VM

La máquina virtual fue configurada en modo NAT, lo cual es suficiente para este escenario ya que únicamente se requiere conectividad saliente hacia smtp.gmail.com. El modo Bridged sería necesario solo si agentes externos necesitaran conectarse hacia la VM. Aunque en ambos modos debería de funcionar.



CONFIGURACIÓN E IMPLEMENTACIÓN

Ingresamos a nuestra herramienta de ingeniería social SET:

```
┌──(kali㉿mail)-[~]
└─$ sudo setoolkit
```

```
[---]        The Social-Engineer Toolkit (SET)        [---]
[---]        Created by: David Kennedy (ReL1K)        [---]
                      Version: 8.0.3
                   Codename: 'Maverick'
[---]        Follow us on Twitter: @TrustedSec        [---]
[---]        Follow me on Twitter: @HackingDave       [---]
[---]       Homepage: https://www.trustedsec.com      [---]
        Welcome to the Social-Engineer Toolkit (SET).
         The one stop shop for all of your SE needs.

  The Social-Engineer Toolkit is a product of TrustedSec.

           Visit: https://www.trustedsec.com

  It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

 Select from the menu:

   1) Social-Engineering Attacks
   2) Penetration Testing (Fast-Track)
   3) Third Party Modules
   4) Update the Social-Engineer Toolkit
   5) Update SET configuration
   6) Help, Credits, and About

  99) Exit the Social-Engineer Toolkit
```

CONFIGURACIÓN E IMPLEMENTACIÓN

Seleccionamos ataques de ingeniería social 1:

```
 Select from the menu:

   1) Social-Engineering Attacks
   2) Penetration Testing (Fast-Track)
   3) Third Party Modules
   4) Update the Social-Engineer Toolkit
   5) Update SET configuration
   6) Help, Credits, and About

  99) Exit the Social-Engineer Toolkit

set> 1
```

Posteriormente seleccionamos 5 Mass Mailer Attack:

```
 Select from the menu:

   1) Spear-Phishing Attack Vectors
   2) Website Attack Vectors
   3) Infectious Media Generator
   4) Create a Payload and Listener
   5) Mass Mailer Attack
   6) Arduino-Based Attack Vector
   7) Wireless Access Point Attack Vector
   8) QRCode Generator Attack Vector
   9) Powershell Attack Vectors
  10) Third Party Modules

  99) Return back to the main menu.

set> 5
```

CONFIGURACIÓN E IMPLEMENTACIÓN

Después de seleccionar Mass Mailer Attack seleccionamos la opción 1:

```
   Social Engineer Toolkit Mass E-Mailer

   There are two options on the mass e-mailer, the first would
   be to send an email to one individual person. The second option
   will allow you to import a list and send it to as many people as
   you want within that list.

   What do you want to do:

    1.  E-Mail Attack Single Email Address
    2.  E-Mail Attack Mass Mailer

    99. Return to main menu.

set:mailer>1
```

Seleccionamos una plantilla predefinida 1:

```
       Do you want to use a predefined template or craft
       a one time email template.

       1. Pre-Defined Template
       2. One-Time Use Email Template

set:phishing>1
```

CONFIGURACIÓN E IMPLEMENTACIÓN

Podemos seleccionar cualquier plantilla, en este caso elegiremos la 7:

```
set:phishing>1
[-] Available templates:
1: Strange internet usage from your computer
2: Computer Issue
3: Dan Brown's Angels & Demons
4: New Update
5: Have you seen this?
6: How long has it been?
7: Status Report
8: Order Confirmation
9: Urgent Security Updates
10: Baby Pics
11: WOAAAA!!!!!!!!!! This is crazy...
set:phishing>7
```

Para representar y ejemplificar, enviaremos el supuesto ataque al correo de uno de los miembro del equipo:

```
set:phishing> Send email to: 181700@upslp.edu.mx

  1. Use a gmail Account for your email attack.
  2. Use your own server or open relay

set:phishing>2
```

CONFIGURACIÓN E IMPLEMENTACIÓN

En la dirección From address usamos la que configuramos en postfix y donde obtuvimos la clave: equipo5testingset@gmail.com

En FROM NAME usamos cualquier nombre que deseemos: 3QU1P05

En Username y Password for open-relay dejamos todo en blanco, ya que nostros ya nos autentificamos en sasl_passwd

En SMTP email address usamos la IP que dejamos para nuestro servidor :127.0.0.1

Ponemos el puerto que estamos usando (viene predeterminado): 25

Podemos marcar el mensaje como alta prioridad, en este caso no lo haremos.

```
set:phishing> From address (ex: moo@example.com): equipo5testingset@gmail.com
set:phishing> The FROM NAME the user will see: 3QU1P05
set:phishing> Username for open-relay [blank]:
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com): 127.0.0.1
set:phishing> Port number for the SMTP server [25]: 25
set:phishing> Flag this message/s as high priority? [yes|no]: n
```

CONFIGURACIÓN E IMPLEMENTACIÓN

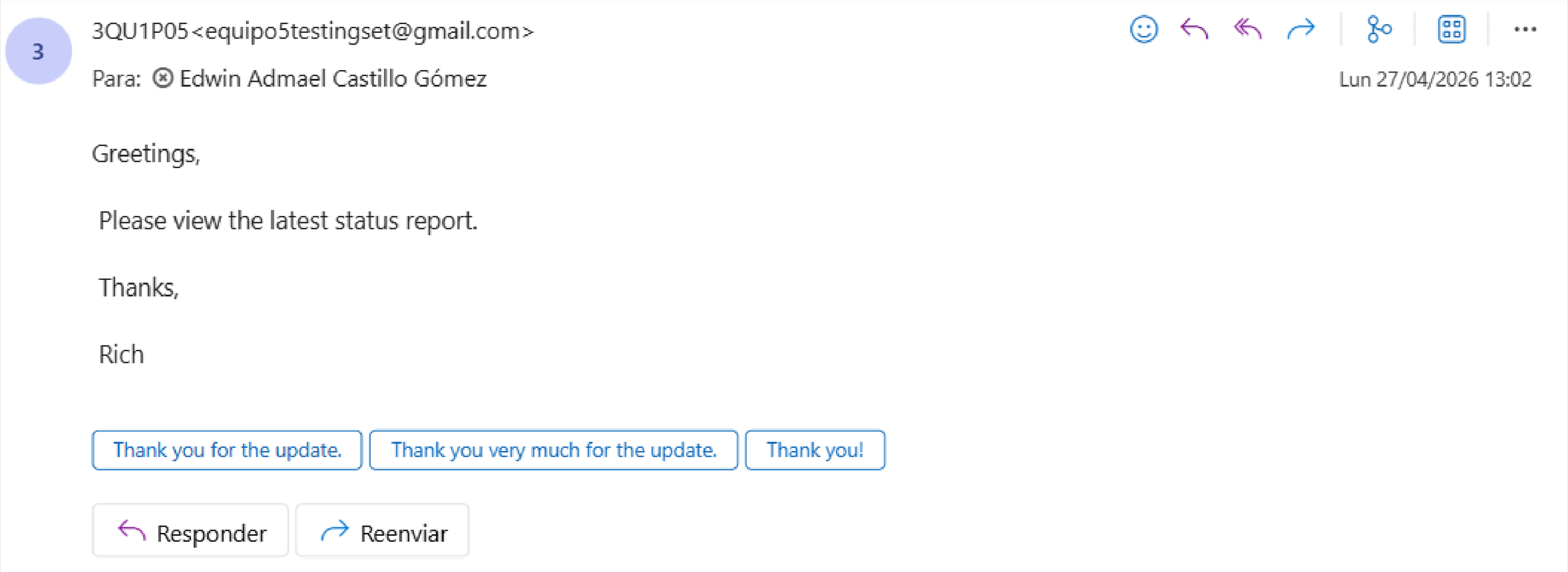
Podemos adjuntar un archivo mediante la opción “Attach file”, lo cual lo incluiría como un archivo separado dentro del correo. En este caso, por simplicidad y para evitar posibles bloqueos por parte de los filtros de seguridad, se decidió no utilizar esta opción.
Asimismo, es posible incluir un archivo como “Inline file”, el cual se integra directamente en el cuerpo del mensaje (por ejemplo, como una imagen visible), sin necesidad de que el destinatario lo descargue. Sin embargo, su visualización dependerá de las políticas del cliente de correo, como es en este caso Microsoft Outlook.

```
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
[*] SET has finished sending the emails
```

El mensaje “SET has finished sending the emails” indica que la herramienta Social-Engineer Toolkit (SET) ha completado el proceso de envío hacia el servidor SMTP configurado. Sin embargo, esto no garantiza que el correo haya sido entregado exitosamente al destinatario.
Todo depende de que tan bien hayamos seguido los pasos anteriores y del sistema operativo donde se instalo el servidor.

RECEPCIÓN DEL CORREO

Podemos observar que recibimos nuestro correo con los parámetros que configuramos en SETool kit.



RECOMENDACIONES

Una recomendacion en caso de que no funcione correctamente hasta este punto sería verificar los logs del sistema (por ejemplo, con sudo journalctl -u postfix -f) para confirmar si el mensaje fue realmente enviado y aceptado por el servidor destino. Los logs nos ayudarán a ver que error nos esta dando y en donde esta terminando la comunicación SMTP, lo que es bastante útil para hacer troubleshooting.

```
┌──(kali㉿kali)-[~]
└─$ sudo journalctl -u postfix -f
Apr 27 05:01:32 mail.equipo5.local postfix/smtp[65038]: warning: See /usr/share/doc/postfix/NON_BERKELEYDB_README.g
z for more info.
Apr 27 05:01:32 mail.equipo5.local postfix/smtp[65038]: error: open database /etc/postfix/sasl_passwd.db: No such f
ile or directory
Apr 27 05:01:32 mail.equipo5.local postfix/tlsmgr[65039]: warning: /etc/postfix/main.cf, line 101: overriding earli
er entry: smtp_tls_security_level=may
Apr 27 05:01:32 mail.equipo5.local postfix/tlsmgr[65039]: warning: /var/lib/postfix/smtp_scache: hash/btree support
 is deprecated.  Please switch to cdb or lmdb.
Apr 27 05:01:32 mail.equipo5.local postfix/tlsmgr[65039]: warning: See /usr/share/doc/postfix/NON_BERKELEYDB_README
.gz for more info.
Apr 27 05:01:33 mail.equipo5.local postfix/smtp[65038]: warning: hash:/etc/postfix/sasl_passwd is unavailable. open
 database /etc/postfix/sasl_passwd.db: No such file or directory
Apr 27 05:01:33 mail.equipo5.local postfix/smtp[65038]: warning: hash:/etc/postfix/sasl_passwd lookup error for "sm
tp.gmail.com"
Apr 27 05:01:33 mail.equipo5.local postfix/smtp[65038]: warning: A7745C050B: smtp_sasl_password_maps lookup error
Apr 27 05:01:33 mail.equipo5.local postfix/bounce[65048]: warning: /etc/postfix/main.cf, line 101: overriding earli
er entry: smtp_tls_security_level=may
Apr 27 05:01:33 mail.equipo5.local postfix/smtp[65038]: A7745C050B: to=<181700@upslp.edu.mx>, relay=smtp.gmail.com[
142.250.138.108]:587, delay=0.55, delays=0.02/0.06/0.46/0, tls=encrypt, dsn=4.3.0, status=deferred (local data erro
r while talking to smtp.gmail.com[142.250.138.108])
```

RECOMENDACIONES

Algunos problemas a los que nos enfrentamos fueron los siguientes:

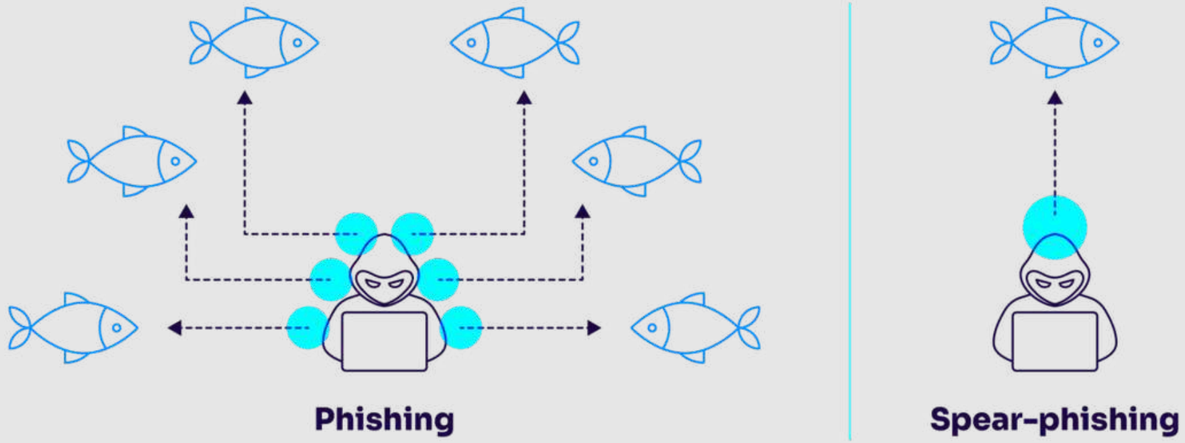
Problema	Causa	Solución
Envío directo rechazado por Outlook	IP sin reputación, falta de SPF/DKIM, dominio local no válido	Implementación de relay SMTP a través de Gmail
App Password no disponible en Google	2FA activado solo con códigos de respaldo; Google requiere método adicional	Agregar Google Authenticator como segundo factor
Error: sasl_passwd.db no encontrado	Postfix requiere archivo compilado, no solo el texto plano	Ejecutar sudo postmap /etc/postfix/sasl_passwd
Formato incorrecto en sasl_passwd_maps	Kali usa Postfix compilado con soporte CDB, no Berkeley DB (hash)	Cambiar hash:/etc/postfix/sasl_passwd a cdb:/etc/postfix/sasl_passwd
Comando mail no disponible	Paquete mailutils no instalado por defecto	sudo apt install mailutils -y
Hostname incorrecto en headers	Sistema usaba kali como hostname por defecto	Editar /etc/hosts y usar hostnamectl set-hostname Equipo5
SMTP Auth deshabilitado en Outlook	Microsoft deshabilita SmtpClientAuthentication por defecto en cuentas nuevas	Cambiar relay a Gmail como alternativa funcional

ENVÍO FINAL

Ya aprendido como se realizó todo, en esta parte enviaremos un correo mas “elaborado” a la direccón: servando.lopez@upslp.edu.mx

```
 Select from the menu:

   1) Spear-Phishing Attack Vectors
   2) Website Attack Vectors
   3) Infectious Media Generator
   4) Create a Payload and Listener
   5) Mass Mailer Attack
   6) Arduino-Based Attack Vector
   7) Wireless Access Point Attack Vector
   8) QRCode Generator Attack Vector
   9) Powershell Attack Vectors
  10) Third Party Modules

  99) Return back to the main menu.

set> 5

   Social Engineer Toolkit Mass E-Mailer

   There are two options on the mass e-mailer, the first would
   be to send an email to one individual person. The second option
   will allow you to import a list and send it to as many people as
   you want within that list.

   What do you want to do:

    1.  E-Mail Attack Single Email Address
    2.  E-Mail Attack Mass Mailer

    99. Return to main menu.

set:mailer>1
```

Seleccionamos 5) Mass Mailer Attack, después 1. E-Mail Attack Single Email Address ya que nuestro único objetivo es que el phishing llegué a la dirección de correo mencionada.



ENVÍO FINAL

Para una visualización mas realista del phishing, creamos un breve diseño en VSC, elegimos que el tipo de mensaje sea en HTML, copiamos de VSC y pegamos en todo el código HTML en donde se nos solicita el cuerpo del mensaje. Finalmente seleccionamos nuestro correo objetivo para el phishing.

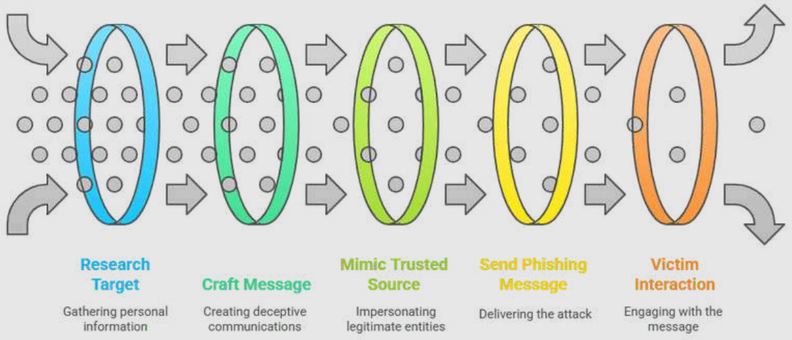
```html
<div style="font-family:Arial,sans-serif;max-width:600px;margin:auto;border:1px solid #ddd;padding:20px;">
  <div style="background:#003366;padding:15px;text-align:center;">
    <h2 style="color:white;margin:0;">Universidad Politécnica de SLP</h2>
    <p style="color:#aad4f5;margin:5px 0;">Departamento de Sistemas y TI</p>
  </div>
  <div style="padding:20px;">
    <p>Estimado usuario,</p>
    <p>Hemos detectado actividad inusual en tu cuenta institucional. Por seguridad, es necesario que <strong>actualices tu contraseña</strong> en las próximas 24 horas.</p
    <p>Si no realizas este proceso, tu cuenta será <strong>suspendida temporalmente</strong>.</p>
    <div style="text-align:center;margin:30px 0;">
      <a href="https://www.upslp.edu.mx" style="background:#003366;color:white;padding:12px 30px;text-decoration:none;border-radius:5px;font-size:16px;">
        Actualizar contraseña
      </a>
    </div>
    <p style="font-size:12px;color:#999;">Este es un mensaje automático del sistema institucional. No responda a este correo.</p>
  </div>
</div>
```

```
set:phishing> Subject of the email: UPSLP
set:phishing> Send the message as html or plain? 'h' or 'p' [p]: h
[!] IMPORTANT: When finished, type END (all capital) then hit {return} on a new line.
set:phishing> Enter the body of the message, type END (capitals) when finished: <div style="font-family:Arial,sans-
serif;max-width:600px;margin:auto;border:1px solid #ddd;padding:20px;"><div style="background:#003366;padding:15px;
text-align:center;"><h2 style="color:white;margin:0;">Universidad Politécnica de SLP</h2><p style="color:#aad4f5;ma
rgin:5px 0;">Departamento de Sistemas y TI</p></div><div style="padding:20px;"><p>Estimado usuario,</p><p>Hemos det
ectado actividad inusual en tu cuenta institucional. Por seguridad, es necesario que <strong>actualices tu contrase
ña</strong> en las próximas 24 horas.</p><p>Si no realizas este proceso, tu cuenta será <strong>suspendida temporal
mente</strong>.</p><div style="text-align:center;margin:30px 0;"><a href="https://www.upslp.edu.mx" style="backgrou
nd:#003366;color:white;padding:12px 30px;text-decoration:none;border-radius:5px;font-size:16px;">Actualizar contras
eña</a></div><p style="font-size:12px;color:#999;">Este es un mensaje automático del sistema institucional. No resp
onda a este correo.</p></div></div>
Next line of the body: END
set:phishing> Send email to: servando.lopez@upslp.edu.mx
```

ENVÍO FINAL

Una vez redactado el template, SET solicita el método de envío. Se seleccionó la opción 2 (Use your own server or open relay) para utilizar el servidor Postfix configurado localmente:

```
  1. Use a gmail Account for your email attack.
  2. Use your own server or open relay

set:phishing>2
set:phishing> From address (ex: moo@example.com): equipo5testingset@gmail.com
set:phishing> The FROM NAME the user will see: UPSLP
set:phishing> Username for open-relay [blank]:
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com): 127.0.0.1
set:phishing> Port number for the SMTP server [25]:
set:phishing> Flag this message/s as high priority? [yes|no]: y
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
[*] SET has finished sending the emails
```



VALORES EN LOS PARÁMETROS

- **From address:** cuenta Gmail usada como identidad del remitente (en este caso usamos el correo configurado con Postfix pero en realidad puede ser cualquier correo)
- **FROM NAME:** nombre visible para el destinatario, suplantando a UPSLP
- **Usuario/Password en blanco:** Postfix maneja la autenticación con Gmail internamente, SET solo entrega el correo al relay local
- **127.0.0.1 puerto 25:** dirección del servidor Postfix corriendo localmente en la misma máquina
- **Alta prioridad:** marca el correo como urgente para generar sensación de inmediatez en la víctima

ENVÍO FINAL

Recibirá un correo con el siguiente contenido:

Importancia alta

Universidad Politécnica de SLP

Departamento de Sistemas y TI

Estimado usuario,

Hemos detectado actividad inusual en tu cuenta institucional. Por seguridad, es necesario que **actualices tu contraseña** en las próximas 24 horas.

Si no realizas este proceso, tu cuenta será **suspendida temporalmente**.

Actualizar contraseña

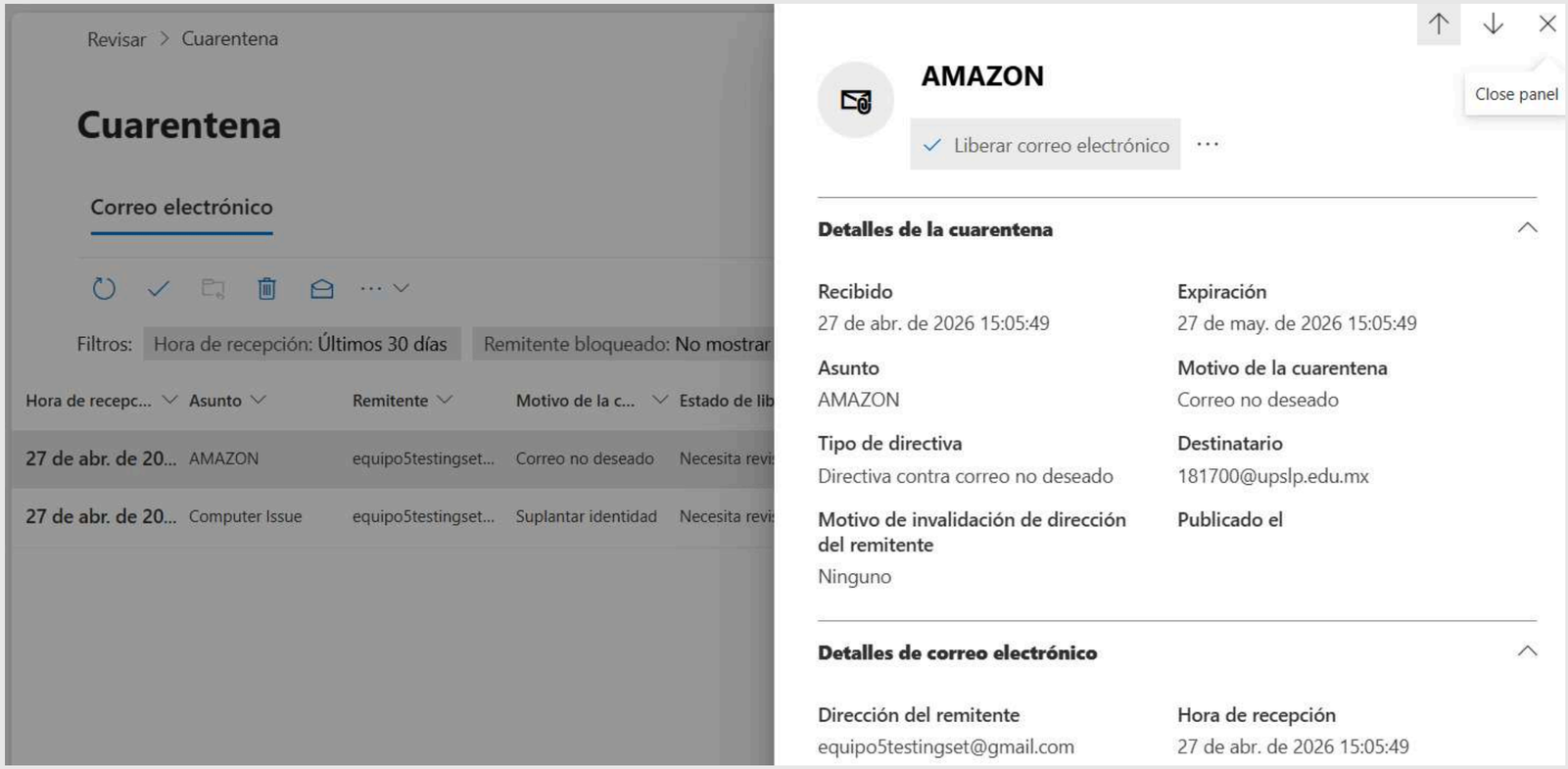
Este es un mensaje automático del sistema institucional. No responda a este correo.

El link actualizar contraseña nos manda la ́página oficial de la UPSLP (nada malicioso en este único caso).

NOTAS IMPORTANTES

Puede que la institucion bloquee los correos y los mande a cuarentena, así que para poder checarlos y liberarlos nos vamos a la página: https://security.microsoft.com/quarantine

Y seleccionamos liberar correo elctrónico. Esto es algo que solo se hace en este caso debido a que estos correos no son del todo maliciosos pero de ninguna manera debemos liberar correos de remitentes desconocidos.



GOOGLE ADMIN TOOLBOX

Para verificar que el correo simulado recorrió correctamente la infraestructura configurada, se utilizó Google Admin Toolbox Message Header Analyzer (toolbox.googleapps.com/apps/messageheader), herramienta oficial de Google que permite visualizar el trayecto completo de un correo entre servidores SMTP.
Se abrió el correo recibido, se seleccionó Mostrar original y se pegaron los headers en la herramienta.
Podemos observar que en el primer salto sale desde nuesto servidor configurado.

#	Delay	From *			To *	Protocol	Time received
0		localhost	→		mail.equipo5.local	ESMTP	27/4/2026, 18:12:07 GMT-6
1	6 sec	mail.equipo5.local	→		smtp.gmail.com		27/4/2026, 18:12:13 GMT-6
2	1 sec		→		2002:a05:6871:50cb:b0:42c:dea:d370	SMTP	27/4/2026, 18:12:14 GMT-6
3	1 sec		→	[Google]	mail-oa1-x33.google.com	SMTP	27/4/2026, 18:12:15 GMT-6
4		SA2PEPF00001508.namprd04.prod.outlook.com	→		PH7P220CA0137.outlook.office365.com		27/4/2026, 18:12:15 GMT-6
5	4 sec	IA3PR13MB6909.namprd13.prod.outlook.com	→		SA5PR13MB7610.namprd13.prod.outlook.com		27/4/2026, 18:12:19 GMT-6

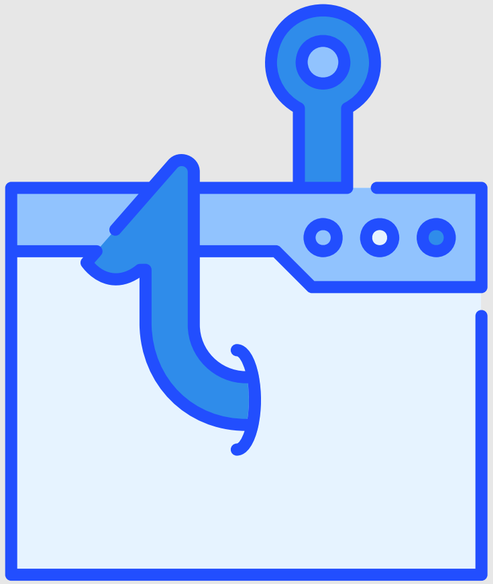
ALTERNATIVA

Las siguientes diapositivas documentan un enfoque alternativo y no forman parte del flujo principal de la práctica. Se incluyen con fines exploratorios para demostrar que existen métodos de relay de paga — como el registro de un dominio real con typosquatting — que ofrecen mayor credibilidad ante los filtros institucionales y menor probabilidad de bloqueo en comparación con el relay gratuito vía Gmail utilizado en la práctica principal.

ALTERNATIVA A POSTFIX PARA EL SMTP

Para la ejecución de este laboratorio, existen distintas metodologías funcionales para el envío de los vectores de ataque:

- Uso de cuentas comerciales: Una alternativa es el envío a través de servicios gratuitos como Gmail, utilizando contraseñas de aplicación para la autenticación del servicio.
- Uso de dominio propio: Otra alternativa es el despliegue de una infraestructura con un dominio profesional y un relevo SMTP, que es el método detallado en este documento para el análisis de reputación DNS y bypass de filtros.



FASE DE RECONOCIMIENTO Y ADQUISICIÓN (INFRAESTRUCTURA)

Esta fase es el cimiento de la campaña. Sin una identidad digital configurada correctamente, los servidores de destino (como Outlook de la UPSLP) rechazarían la conexión antes de que el correo siquiera sea leído.

A. Adquisición de Dominio (Typosquatting)

1. Selección del nombre: Se realizó un análisis de disponibilidad buscando un dominio que visualmente engañara al usuario. Se eligió upslp-edu.xyz porque imita la estructura de correos educativos pero bajo una terminación .xyz, común en proyectos tecnológicos.
2. Registro: Se utilizó el registrador Namecheap. Tras la compra, se obtuvo acceso al panel de Advanced DNS, que es el centro de mando para la identidad del dominio.

namecheap

FASE DE RECONOCIMIENTO Y ADQUISICIÓN (INFRAESTRUCTURA)

Registros de Autenticación DKIM (Brevo & SMTP2GO)

En tu captura se ven cuatro registros CNAME clave que funcionan como la "identificación oficial" de tu dominio:

1. **DKIM de Respaldo (Brevo): Configuramos los registros brevo1._domainkey_ y brevo2._domainkey_ Estos aseguran que el dominio tenga llaves criptográficas activas para firmar los correos.**
2. **Retorno de Ruta (SMTP2GO): El registro con host em1046107 apuntando a return.smtp2go.net. Este es vital; le dice a los servidores de Microsoft: "Si este correo tiene algún problema, devuélvelo a la oficina de SMTP2GO". Esto aumenta drásticamente la confianza del filtro de spam.**
3. **Seguimiento de Enlaces (Track): El registro con host link apuntando a track.smtp2go.net. Este permite que, cuando mandes el link en tu correo de phishing, SMTP2GO pueda decirte en tiempo real si la víctima le dio clic.**

A Record	@	[redacted]	1 min	

FASE DE RECONOCIMIENTO Y ADQUISICIÓN (INFRAESTRUCTURA)

B. Registros de Autenticación y Trazabilidad (DKIM y CNAME)

Para consolidar la legitimidad del dominio ante los firewalls de correo de última generación, se implementaron registros de tipo CNAME que funcionan como la identificación oficial de la infraestructura. Estos registros permiten que el dominio no sea clasificado como una fuente anónima o maliciosa.

I. Implementación de llaves criptográficas (DKIM)

Se configuraron registros específicos (brevo1._domainkey y brevo2._domainkey) destinados a la autenticación DKIM (DomainKeys Identified Mail). Esta tecnología añade una firma digital invisible en la cabecera de cada correo electrónico enviado. Cuando el servidor de la universidad recibe el mensaje, utiliza estos registros para verificar mediante criptografía que el correo realmente proviene del dominio autorizado y que su contenido no fue alterado durante el tránsito por internet.

CNAME Record	brevo1._domain...	b1.upslp-edu-xyz.dkim.brevo.com.	5 min	
CNAME Record	brevo2._domain...	b2.upslp-edu-xyz.dkim.brevo.com.	5 min	

FASE DE RECONOCIMIENTO Y ADQUISICIÓN (INFRAESTRUCTURA)

II. Gestión del Retorno de Ruta (Return-Path)

Se estableció un registro técnico apuntando a return.smtp2go.net (Host: em1046107). Este parámetro es fundamental para la reputación del remitente, ya que define una dirección de retorno válida para los mensajes de error o "rebotes". Al contar con una ruta de retorno verificada, los filtros de seguridad de Microsoft 365 incrementan el nivel de confianza sobre el dominio, al confirmar que existe una infraestructura responsable detrás de la emisión del mensaje.

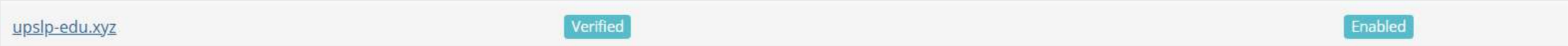
CNAME Record	em1046107	return.smtp2go.net.	Automatic	

FASE DE INTERMEDIACIÓN: CONFIGURACIÓN DEL RELAY SMTP

Una vez establecida la identidad del dominio en el DNS, la siguiente fase consistió en habilitar un canal de comunicación seguro y de alta reputación entre el servidor local (Kali Linux) y el servidor de destino (Microsoft 365). Para ello, se integró un servicio de Relay SMTP profesional a través de la plataforma SMTP2GO.

A. Vinculación y Validación de Infraestructura

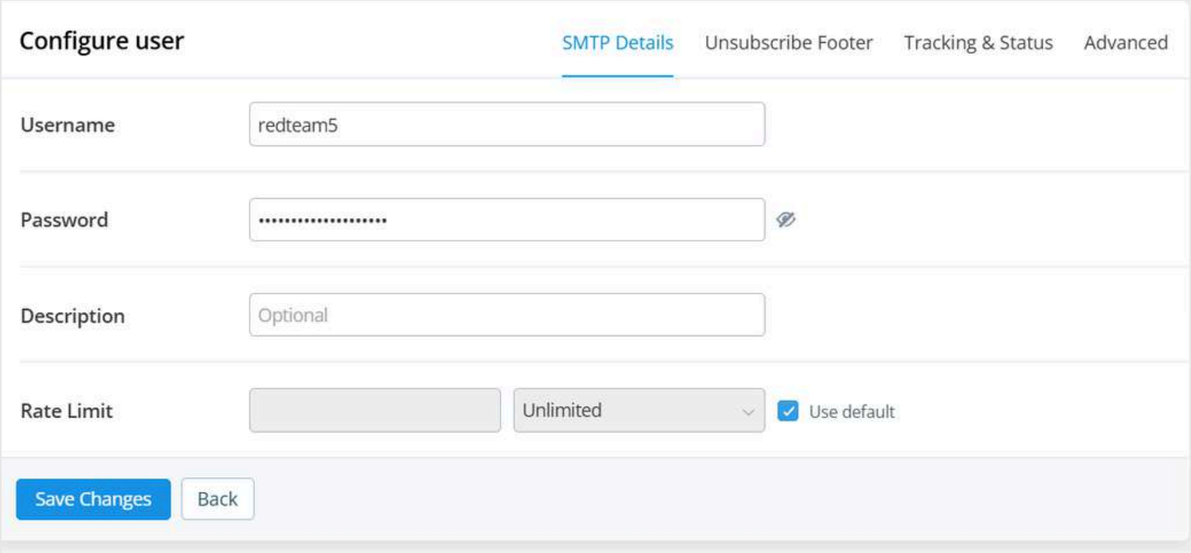
El primer paso en esta fase fue la sincronización del dominio upslp-edu.xyz con el panel de control del proveedor de relay. El sistema realizó una consulta hacia los registros DNS previamente configurados en Namecheap para validar la propiedad del dominio. Tras confirmar la presencia de los registros CNAME y MX, el estado del dominio cambió a "Verified", lo que otorgó al atacante la capacidad de enviar correos electrónicos firmados digitalmente, aumentando drásticamente la probabilidad de evadir los filtros de spam automáticos.



FASE DE INTERMEDIACIÓN: CONFIGURACIÓN DEL RELAY SMTP

B. Creación de Credenciales de Autenticación

Para permitir que la máquina atacante se comunicara con el relay, se generaron credenciales de usuario específicas. Estas credenciales actúan como una "llave de acceso" que Postfix (el servidor de correo en Kali) utiliza para identificarse ante SMTP2GO. Este método es preferible al envío directo, ya que utiliza la reputación de las direcciones IP del proveedor de relay, ocultando la dirección IP residencial o local del atacante, la cual suele tener una reputación nula o negativa ante los firewalls corporativos.



FASE DE INTERMEDIACIÓN: CONFIGURACIÓN DEL RELAY SMTP

C. Monitoreo de Entrega en Tiempo Real (Master Logs)

Se habilitó el acceso al Master Log (o panel de actividad), una herramienta de auditoría fundamental para la fase de reconocimiento de entrega. Este panel permite observar el ciclo de vida del mensaje enviado:

1. **Processed:** Indica que el relay recibió el correo desde Kali Linux con éxito.
2. **Delivered:** Confirma que el servidor de la universidad aceptó la conexión y el paquete de datos.
3. **Bounced/Rejected:** En caso de falla, proporciona el código de error exacto emitido por el firewall de destino, permitiendo al atacante ajustar el vector de ataque en tiempo real.

Date	Event	Recipient	Subject
7:45:43 PM	Hard Bounce	root@upslp-edu.xyz	*** SECURITY information for kali ***
7:45:23 PM	Delivered	182217@upslp.edu.mx	Have you seen this?
7:17:15 PM	Delivered	182217@upslp.edu.mx	Have you seen this?
04/24/2026 10:11:14 PM	Rejected	osvaldo.hernandez1311@gmail.com	AVISO: Seguridad de cuenta UPSLP

FASE DE INTERMEDIACIÓN: CONFIGURACIÓN DEL RELAY SMTP

C. Monitoreo de Entrega en Tiempo Real (Master Logs)

Se habilitó el acceso al Master Log (o panel de actividad), una herramienta de auditoría fundamental para la fase de reconocimiento de entrega. Este panel permite observar el ciclo de vida del mensaje enviado:

1. **Processed:** Indica que el relay recibió el correo desde Kali Linux con éxito.
2. **Delivered:** Confirma que el servidor de la universidad aceptó la conexión y el paquete de datos.
3. **Bounced/Rejected:** En caso de falla, proporciona el código de error exacto emitido por el firewall de destino, permitiendo al atacante ajustar el vector de ataque en tiempo real.

Date	Event	Recipient	Subject
7:45:43 PM	Hard Bounce	root@upslp-edu.xyz	*** SECURITY information for kali ***
7:45:23 PM	Delivered	182217@upslp.edu.mx	Have you seen this?
7:17:15 PM	Delivered	182217@upslp.edu.mx	Have you seen this?
04/24/2026 10:11:14 PM	Rejected	osvaldo.hernandez1311@gmail.com	AVISO: Seguridad de cuenta UPSLP

FASE DE CONFIGURACIÓN DEL SERVIDOR DE ATAQUE (KALI LINUX)

En esta etapa, el objetivo fue transformar la distribución Kali Linux en un nodo emisor de correo capaz de interactuar con el relay profesional. Esto requirió la instalación y el endurecimiento de un Agente de Transferencia de Correo (MTA).

A. Instalación y Preparación de Postfix

Se seleccionó Postfix como el motor de mensajería principal debido a su robustez y compatibilidad con protocolos de seguridad modernos. El proceso comenzó con la instalación del paquete y la detención de cualquier otro servicio de correo que pudiera generar conflictos de puertos (como Exim).

SIET